

Event Information:

EventID :
119
Event Time :
Feb, 28, 2022, 10:48 PM
Rule :
SOC169 - Possible IDOR Attack Detected
Level :
Security Analyst
Hostname :
WebServer1005
Destination IP Address :
172.16.17.15
Source IP Address :
134.209.118.137
HTTP Request Method :
POST
Requested URL :
https://172.16.17.15/get_user_info/
User-Agent :
Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; .NET CLR 1.1.4322)
Alert Trigger Reason :
consecutive requests to the same page
Device Action :
Allowed

Analysis Steps:

The network logs were filtered to the relevant IPs and time-frame for this suspicious event. It was found that queries typical of a IDOR attack were identified with the threat actor querying for ?user_id= 1 through 5 on the /get_user_info/ page.

time	Feb, 28, 2022, 10:45 PM
Raw Log	
Request URL	https://172.16.17.15/get_user_info/
User-Agent	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; .NET CLR 1.1.4322)
Request Method	POST
Device Action	Permitted
HTTP Response Size:	188
HTTP Response Status	200
POST Parameters	?user_id=1

time	Feb, 28, 2022, 10:48 PM
Raw Log	
Request URL	https://172.16.17.15/get_user_info/
User-Agent	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1; .NET CLR 1.1.4322)
Request Method	POST
Device Action	Permitted
HTTP Response Size:	267
HTTP Response Status	200
POST Parameters	?user_id=5

The responses to these POST requests were of varying size for each. This would indicate that the threat actor was being served confidential user information rather than being redirected to a default page. This supports the notion that the attack was a success.

The IP involved in the attack 134[.]209.118.137 is external to our operations and is not in our vulnerability database at present. It is a United States address associated with AS 14061 (DigitalOcean, LLC). No vendors on VirusTotal currently list this address as malicious. I have searched for planned penetration testing emails involving this IP as the source and found no results.

0

/ 91

Community Score

-5

No security vendor flagged this IP address as malicious

Reanalyze

More

134.209.118.137 (134.209.0.0/16)

AS 14061 (DigitalOcean, LLC)

US

Last Analysis Date a moment ago

DETECTION

DETAILS

RELATIONS

COMMUNITY 9

Join our Community and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Security vendors' analysis

Do you want to automate checks?

Abusix	Clean	Acronis	Clean
ADMINUSLabs	Clean	AILabs (MONITORAPP)	Clean
AlienVault	Clean	Antiy-AVL	Clean

This attack relates to WebServer1005 and it has been contained to limit the possibility for any further sensitive information from being exfiltrated until this vulnerability can be resolved. As the evidence suggests strongly towards this being a successful true positive it has been escalated for further analysis.

```

119
Feb, 28, 2022, 10:48 PM
SOC169 - Possible IDOR Attack Detected
True Positive (+5 Point)
Do You Need Tier 2 Escalation? (+5 Point)
Was the Attack Successful? (+5 Point)
What Is the Direction of Traffic? (+5 Point)
Check If It Is a Planned Test (+5 Point)
What Is The Attack Type? (+5 Point)
Is Traffic Malicious? (+5 Point)

```

Report:

Incident Summary

Analysis confirms a True Positive IDOR attack against WebServer1005. An external threat actor successfully extracted confidential user information via the /get_user_info/ endpoint. The host has been contained and the ticket is escalated to Tier 2 for further review.

Incident Details

- **Alert Name:** SOC169 - Possible IDOR Attack Detected
- **Attacker IP:** 134[.]209.118.137 (AS 14061 - DigitalOcean, LLC)
- **Target Host:** WebServer1005 (172[.]16.17.15)
- **Attack Vector:** HTTP POST requests

Analysis and Evidence

- **Attack Execution:** The attacker issued consecutive POST requests to [hxxps://172[.]16.17.15/get_user_info/].
- **Payload Modification:** The attacker systematically modified the POST parameter ?user_id= from 1 through 5.
- **Success Confirmation:** The server responded with HTTP Status 200 (Permitted) for all requests. HTTP Response Sizes varied (188 bytes for user_id=1, 267 bytes for user_id=5), confirming unique data was exfiltrated rather than a static error page served.

Threat Intelligence

- **OSINT:** The IP is not in our database and VirusTotal currently lists the source IP as clean across all vendors.
- **Internal Correlation:** A review of internal communications confirmed no authorised penetration testing is scheduled for this IP or subnet.

Actions Taken

1. Contained WebServer1005 to prevent further data exfiltration.
2. Declared True Positive.
3. Escalated to Tier 2 for impact assessment and remediation.